

Paper V1 — Rewritten Manuscript (measurement-framed)

Status. Sections 1–6 and 8 (methodology), 10, 11 are written now and are final-ready pending minor polish. Sections 7 (Results) and parts of 9 (Discussion)/12 (Conclusion) are **scaffolded with explicit `[FILL]` placeholders and empty table shells** to be completed once the testbed (see the Build Plan) produces data. **No results have been invented.** Where a sentence depends on a measured outcome, it is written as a conditional/pre-registered claim and marked.

Format note. Delivered as Markdown for easy editing. Say the word and I'll render this as Elsevier `[elsarticle]` LaTeX. Citation keys reuse your existing bibliography where possible; new comparators are marked `[VERIFY]` and must be confirmed before submission.

Title (revised)

What Does Continuous Zero Trust Add Over FAPI 2.0? An Empirical Measurement of Context-Bound Enforcement for Open Banking APIs Against Device-Resident and Account-Takeover Adversaries

(Shorter alternative: "Beyond Proof-of-Possession: Measuring Context-Bound Zero Trust Enforcement for Open Banking APIs.")

Abstract (target — numeric placeholders to fill after experiments)

Open Banking APIs increasingly adopt the FAPI 2.0 security profile, which mandates sender-constrained access tokens via DPoP or mTLS and thereby neutralizes network-level token replay and theft of tokens without the associated key. This raises a question that, to our knowledge, has not been answered with measurement: once a deployment is already FAPI 2.0-correct, what does an additional layer of continuous, context-bound Zero Trust enforcement actually buy, and at what cost? We build a reproducible, fully synthetic Open Banking testbed — a Basiq-isomorphic Accredited Data Recipient API, a Keycloak identity provider configured to the FAPI 2.0 DPoP profile, and a Zero Trust controller that performs per-request device-binding, telemetry, rule-based risk scoring, and adaptive `[ALLOW/CHALLENGE/DENY]` decisions — and we evaluate three configurations under an identical attacker suite: a weak bearer-token baseline (B0), a standards-correct FAPI 2.0/DPoP baseline (B1), and the proposed continuous-enforcement system (P). Crucially, our attacker taxonomy includes adversaries that DPoP alone does not stop: device-resident key abuse and account takeover from a newly enrolled device. We find that `[FILL: for network replay and token-theft-without-key]`, B1 already blocks X% of attacks and P adds no measurable security benefit, while `[FILL: for device-resident and ATO-class attacks]`, B1 blocks only Y% whereas P blocks Z%, at a per-request overhead of `[FILL: median +A ms, p99 +B ms]` dominated by `[FILL: policy/telemetry]` rather than cryptography, and a false-challenge rate on legitimate traffic under context drift of `[FILL: C%]`. An ablation attributes the security gain primarily to `[FILL: component]` and the operational cost primarily to `[FILL: component]`. We release the testbed, attack suite, and analysis pipeline to support replication. Our contribution is not a new mechanism but a measured characterization of the security/cost boundary of continuous Zero Trust enforcement over a modern financial-API baseline.

Keywords: Open Banking, FAPI 2.0, DPoP, Zero Trust, continuous authorization, session hijacking, account takeover, empirical security evaluation.

1. Introduction

Open Banking has expanded rapidly under regulatory mandates such as the EU's PSD2 [1] and Australia's Consumer Data Right [2], exposing consumer-permissioned financial data through standardized APIs and correspondingly enlarging the attack surface across heterogeneous devices, networks, and third parties. A recurring concern in both formal and empirical literature is that session-level and token-level compromise — session hijacking, token replay, and account takeover — remain viable even where strong cryptography is deployed [17, 18, 19, 20].

The industry response has consolidated around the Financial-grade API (FAPI) 2.0 Security Profile, which reached final specification status in 2025 and mandates Pushed Authorization Requests, PKCE for all clients, and **sender-constrained access tokens** via either mTLS (RFC 8705) or DPoP (RFC 9449) [VERIFY: FAPI 2.0 final, OpenID Foundation, 2025]. Sender-constraining is significant: by binding a token to a client-held key and requiring a fresh proof-of-possession on each call, it renders a stolen bearer token unusable to any party lacking the private key. This directly defeats the classic network-interception and browser-storage-exfiltration attacks that motivate much prior work. Commodity identity infrastructure now supports this natively — for example, DPoP and dedicated FAPI 2.0 DPoP client profiles are officially supported in mainstream identity servers [VERIFY: Keycloak 26.4 release notes, 2025].

This creates a subtle and, we argue, unresolved research question. Much of the security benefit attributed to "Zero Trust for Open Banking" in recent architectural proposals is, in fact, already delivered by a correctly configured FAPI 2.0 baseline. The genuinely open question is what a *further* layer of continuous, context-bound Zero Trust enforcement — per-request telemetry, device-binding beyond token possession, risk scoring, and adaptive challenge/deny — contributes **on top of** that baseline, and what it costs. This matters precisely for the adversaries that proof-of-possession does *not* stop: an attacker operating on the legitimate device (and therefore able to produce valid DPoP proofs), and an attacker who takes over an account and enrolls or uses their own device. For these, cryptographic sender-constraining is silent, and only behavioral/contextual enforcement can respond.

Existing work does not answer this question with measurement. Formal analyses establish protocol-level guarantees and attacks but do not quantify runtime enforcement trade-offs [17, 18, 19]. Empirical studies of anomalous API behavior demonstrate that behavioral signals discriminate compromised sessions [20] but are not integrated with, or measured against, a sender-constrained baseline. Recent architectural proposals for Zero Trust in banking API gateways are largely conceptual, presenting components and standards mappings without an implemented, attacked, and measured evaluation [VERIFY: conceptual ZTA-API-gateway banking paper, 2025]. Game-theoretic Zero Trust authentication frameworks derive belief-threshold policies analytically [22][VERIFY: threshold-POMDP ZT defense, arXiv:2303.03349] but in other domains and without a financial-API measurement. What is missing is a controlled, reproducible measurement of the security benefit and operational cost of continuous Zero Trust enforcement relative to a FAPI 2.0-correct baseline.

Research questions.

- **RQ1.** Against a standards-correct FAPI 2.0/DPoP baseline, which classes of Open Banking attacks remain feasible, and which of these does a continuous context-bound enforcement layer detect or prevent?
- **RQ2.** What per-request latency, throughput, and resource overhead does continuous enforcement impose relative to (a) plain bearer OAuth and (b) FAPI 2.0/DPoP, across increasing

load?

- **RQ3.** Which enforcement components (device-binding, contextual risk, velocity) are responsible for the security gains, and which drive the cost and the false-challenge rate?

Approach. We implement a fully synthetic testbed comprising a Basiq-isomorphic ADR API, a Keycloak IdP configured to the FAPI 2.0 DPoP profile, and a Zero Trust controller, and we evaluate three configurations (B0, B1, P) under an identical, executable attacker suite that explicitly includes device-resident and ATO-class adversaries, plus a legitimate workload with context drift to measure false challenges.

Contributions.

1. An **executable attacker taxonomy** for Open Banking session/token/ATO threats, mapped to what DPoP does and does not mitigate, making explicit the regime where a contextual layer is the *only* remaining defense (§4, §6).
2. A **reproducible testbed and measurement** of the security benefit and operational cost of continuous Zero Trust enforcement over a FAPI 2.0/DPoP baseline (§5, §7), released as open artifacts.
3. An **ablation** attributing the security gains and the false-challenge cost to specific enforcement components (§7.4), turning "we combined mechanisms" into a quantified statement of what the combination buys.

We deliberately do **not** claim a new cryptographic primitive, a new protocol, or a new equilibrium concept; the mechanisms are standard, and our contribution is the measured characterization of their combination.

2. Background

(Compressed relative to Vo — keep only what the measurement needs.)

2.1 Sender-constrained tokens and DPoP. DPoP (RFC 9449) binds an access token to a client-held key by embedding the JWK SHA-256 thumbprint in the token's `(cnf.jkt)` confirmation claim; on each request the client presents a signed DPoP proof JWT carrying `(htm)`, `(htu)`, `(iat)`, `(jti)`, and `(ath)`, which the resource server verifies against the bound thumbprint and for freshness/replay. This yields sender-constraining without the PKI overhead of mTLS, making it suitable for public clients (SPAs, mobile). *(Correct the Vo error: the confirmation is `(cnf.jkt)` — a thumbprint — not `(cnf.jwk)`.)*

2.2 FAPI 2.0. The FAPI 2.0 Security Profile composes PAR, PKCE, sender-constrained tokens (mTLS or DPoP), short-lived tokens, and refresh rotation, and has been subject to formal security analysis [18]. It is the appropriate *baseline* for any modern Open Banking security claim; comparing a proposed system only against plain bearer OAuth overstates novelty.

2.3 Zero Trust Architecture. NIST SP 800-207 [9, 10] frames Zero Trust around per-request verification and continuous, context-aware policy via a Policy Decision Point / Policy Enforcement Point / Policy Information Point decomposition. Applied to APIs, the salient shift is from session-established trust to request-level, continuously re-evaluated trust.

2.4 Cryptographic primitives (brief). We use standard ECC (ES256 / Ed25519) for signatures; the security of sender-constraining rests on the unforgeability of these signatures. ECC is an enabling choice, not a contribution. *(Trim the Vo crypto section heavily; the AES/Argon2/PQC material is not load-bearing for the measurement and invites scope creep — move to a one-paragraph note or cut.)*

3. Related Work

(Reorganized to make the gap defensible and to cite the closest comparators the Vo draft omitted.)

3.1 Formal analyses of Open Banking protocols. Fett et al. [17] give the first extensive formal analysis of FAPI, uncovering session-integrity and authorization attacks that persist under partial or incorrect composition of PKCE, token binding, and mTLS. Hosseini et al. [18] extend this to FAPI 2.0 under a stronger attacker (malicious browsers, network adversaries, leaked TLS-protected messages), motivating sender-constrained tokens. Modesti et al. [19] formally analyze the UK Open Banking Account and Transaction API under unbounded parallel sessions, exposing session-isolation and authorization weaknesses. These works establish *protocol-level* guarantees and attacks; they do not measure runtime enforcement trade-offs, which is our focus.

3.2 Empirical and behavioral analyses. Behbehani et al. [20] show that behavioral features (request frequency, connection duration, repeated access) discriminate anomalous Open Banking API access, implicitly supporting continuous trust evaluation. Wilson and Tam [21] survey Open Banking security across technological, regulatory, and behavioral dimensions. Neither integrates behavioral enforcement with a sender-constrained baseline or quantifies the marginal benefit — the gap we address.

3.3 Game-theoretic and threshold-policy Zero Trust. Ge and Zhu [22] (GAZETA) model Zero Trust authentication as a Markov game with one-sided incomplete information, continuously updating a trust score and deriving policies from equilibrium analysis. Related work derives *explainable belief-threshold* defense policies for account takeover as a POMDP [VERIFY: Ge/Li/Zhu, arXiv:2303.03349]. We note explicitly that belief-threshold structures for Zero Trust are established results; accordingly we do **not** claim a novel equilibrium concept, and we position any analytical model in this paper as a *supporting, calibrated* interpretation of measured behavior rather than a contribution (see Appendix A).

3.4 Architectural Zero Trust for banking APIs. Recent proposals design Zero Trust API-gateway architectures for digital banking using PDP/PEP/PIP decompositions and standards mappings [VERIFY: conceptual ZTA-API-gateway banking, 2025]. Simulation-based evaluations of Zero Trust in financial networks also exist [VERIFY: Daah et al., Computers & Security, 2025]. These are, respectively, conceptual or simulation-oriented; our contribution is an implemented, attacked, and measured comparison isolating the delta over FAPI 2.0.

3.5 Synthesis and gap. The literature establishes (i) formal protocol guarantees and attacks, (ii) that behavioral signals discriminate compromise, and (iii) analytical belief-threshold policies. What remains unmeasured is the **security benefit and operational cost of continuous, context-bound enforcement relative to a FAPI 2.0-correct baseline**, particularly for adversaries that sender-constraining does not stop. This is an *evaluation/measurement* gap, and it is the gap this paper fills.

Gap matrix.

Work	Problem	Method	Mechanism	Evaluation	Gap vs. ours
Fett [17]; Hosseyni [18]	FAPI(2.0) integrity	Formal	PKCE/mTLS/DPoP	Proofs/attacks	No runtime cost/benefit measurement
Modesti [19]	UK OB API	Formal	Session isolation	Unbounded sessions	No enforcement measurement
Behbehani [20]	Anomalous access	ML	Behavioral	Empirical	Not vs. sender-constrained baseline
GAZETA [22]; [VERIFY 2303.03349]	Stolen creds / ATO	Game/POMDP	Belief threshold	Equilibrium/meta- learning	Other domain; not measured on financial API
[VERIFY conceptual ZTA- gateway]	Banking API GW	Conceptual	PDP/PEP/PIP	None	Not implemented/attacked/measured
[VERIFY Daah 2025]	Financial ZT	Simulation	ZT+detection	Simulated	Not isolating delta over FAPI 2.0
This work	Delta over FAPI 2.0	Implemented + attacked + measured	DPoP + context	B0/B1/P + ablation	—

4. Threat Model

We consider an adversary seeking unauthorized access to protected Open Banking resources via session/token compromise. We make the standard cryptographic assumption that ECDSA/Ed25519 signatures and JWT signatures are unforgeable, and that protocol checks are correctly enforced.

Adversary capabilities considered. The adversary may intercept and manipulate network traffic; obtain access tokens via interception or client-side exfiltration; replay captured requests; and, critically, **operate on the legitimate device** (able to invoke the device key) or **take over an account and use a different device**. We distinguish these because sender-constraining defeats the first group but is silent on the last two.

Explicitly in scope (unlike the prior draft). Device-resident key abuse and account takeover from a new device are **in scope**, because they are the only regime in which a contextual enforcement layer can beat a FAPI 2.0 baseline. Scoping them out would eliminate the paper's measurable delta.

Out of scope. Kernel-level malware that silently exfiltrates the private key to an arbitrary remote host is out of scope (though behavioral detection may partially mitigate); we do not claim to defend a fully compromised OS. Attacks on the IdP or on the cryptographic primitives themselves are out of scope.

Adversary–defense map (to be measured, §7):

Adversary	Capability	Stopped by B1 (FAPI 2.0)?	Role of P (context)
Network/MITM replay	Resend captured request	Yes (<code>jti</code>)(<code>iat</code>)	Redundant
Token theft w/o key	Token, not key	Yes (<code>cnf.jkt</code> mismatch)	Redundant
Device-resident abuse	Can sign on device	No	Primary defense (telemetry/velocity/risk)
ATO, new device	Valid creds, own device	No	Device/geo/velocity mismatch → CHALLENGE/DENY
BOLA/BFLA	Access others' objects	Partial (object checks)	Consent-scope + object-level policy
Velocity/consent abuse	High volume / out-of-scope	No	Rate/consent rules

5. System Under Test

We evaluate three configurations sharing one codebase, selected by configuration (not separate systems), so differences are attributable to the enforcement layer rather than implementation variance.

5.1 B0 — Weak baseline. Plain OAuth 2.0 bearer tokens, no sender-constraining, no contextual policy. Included only as a reference point.

5.2 B1 — FAPI 2.0-correct baseline (the real comparator). Keycloak configured to the FAPI 2.0 DPoP client profile: PAR, PKCE (S256), DPoP sender-constrained tokens (`cnf.jkt`), short-lived access tokens, refresh rotation. The controller performs standard token and DPoP verification (signature, thumbprint match, `htm`)(`htu`), `iat` skew, `jti` replay, `ath`) and proxies approved requests. No telemetry, risk, or adaptive policy.

5.3 P — Proposed continuous enforcement. B1 plus, on every request: telemetry collection (device-fingerprint consistency, geo/velocity, call-rate, session continuity, DPoP-failure history), deterministic rule-based risk scoring yielding a legitimacy belief ($b \in [0, 1]$) ($risk = 1 - b$), and an OPA-evaluated adaptive decision — `ALLOW` if $risk < \tau$, `CHALLENGE` if $\tau \leq risk < \tau_{deny}$, `DENY` if $risk \geq \tau_{deny}$. Risk scoring is rule-based, not learned, to keep decisions auditable and deterministic.

5.4 Components. User device (EC keypair, DPoP proof signing); Keycloak IdP (token issuance, `cnf.jkt` binding, device-key registration); Zero Trust controller (PEP+PDP: verification, telemetry, risk, policy, mTLS proxy); mock Basiq-isomorphic ADR resource server (`/users`), (`/accounts`), (`/transactions`), (`/consents`), with per-object ownership to make BOLA/BFLA testable). *(Figures: system-under-test with the B1/P boundary highlighted; end-to-end request flow; both to be finalized from the implementation — replace the Vo broken (Figure ??) references.)*

5.5 Enforcement invariant. Across B1 and P, possession of an access token alone is never sufficient: a valid DPoP proof bound to the token's `(cnf.jkt)` is required. P additionally requires the request to pass contextual risk evaluation. This invariant is what the attacks in §6 probe.

6. Attack Suite (methodology)

We implement six executable attacks, each run against B0/B1/P with fixed seeds and repeated for statistics. Success = the adversary obtains protected data or performs the unauthorized action. For each we log attempts, successes, the stage at which blocking occurred, detection, and time-to-detect.

- **A1 Network replay** — resend a captured valid request. *(Probes redundancy of P; expect B1 sufficient.)*
- **A2 Token theft without key** — use a stolen token from a fresh context lacking the device key. *(Expect B1 sufficient via `(cnf.jkt)` mismatch.)*
- **A3 Device-resident key abuse** — operate on the legitimate device with valid DPoP but anomalous behavior. *(The crux: expect B1 insufficient, P responds.)*
- **A4 ATO from a new device** — valid credentials, different device/key/geo/fingerprint. *(Expect B1 insufficient for authenticated misuse, P responds.)*
- **A5 BOLA/BFLA** — authenticated access to another user's object or function. *(Measures object/consent-level enforcement.)*
- **A6 Velocity/consent abuse** — abnormal volume or out-of-consent access. *(Expect only P throttles/denies.)*

We additionally run a **legitimate workload with context drift** (network change, travel) to measure P's false-challenge and false-deny rates, so the security benefit is reported against its usability cost.

7. Results (SCAFFOLD — to be filled from the testbed; no numbers invented)

Fill each `[FILL]` from `(data/tables/)` and `(data/figures/)` produced by the analysis pipeline.
Report every proportion with a 95% CI and every latency comparison with an effect size.

7.1 Attack outcomes (RQ1). *Table 1 — attack success rate by configuration (with Wilson 95% CIs).*

Attack	B0	B1	P
A1 replay	[FILL]	[FILL]	[FILL]
A2 token theft (no key)	[FILL]	[FILL]	[FILL]
A3 device-resident	[FILL]	[FILL]	[FILL]
A4 ATO new device	[FILL]	[FILL]	[FILL]
A5 BOLA/BFLA	[FILL]	[FILL]	[FILL]
A6 velocity/consent	[FILL]	[FILL]	[FILL]

Narrative (write to the data): We expect to report that B1 reduces A1/A2 to near zero, confirming that sender-constraining alone handles network- and theft-without-key attacks (H1), while B1 remains

vulnerable to A3/A4 and P reduces them to [FILL] (H2). State the actual numbers and whether H1/H2 held.

7.2 False-challenge cost (RQ1/RQ3). *Table 2 — false-challenge / false-deny rate on legitimate traffic under stable vs. drifting context (B1 vs P).* [FILL]

7.3 Performance (RQ2). *Figure — per-request latency distribution (CDF) and stage breakdown; Table 3 — p50/p95/p99 total and per-stage for B0/B1/P; Figure — throughput vs. concurrency; Table 4 — CPU/memory overhead.* [FILL] Report whether crypto or policy/telemetry dominates the added cost (H3).

7.4 Ablation (RQ3). *Table 5 — attack success and false-challenge for P, P-device-binding, P-context, P-velocity, B1.* [FILL] State which component is responsible for the A3/A4 gain and which drives the false-challenge cost (H4).

7.5 Summary of findings. [FILL: 3-5 sentence synthesis tying results to RQ1-RQ3 and H1-H4.]

8. Experimental Methodology (*write-ready; sits before Results in the final layout or as a subsection of §5–6*)

Configurations & isolation. B0/B1/P and ablations are selected by feature flags in one controller codebase; the mock API and IdP are held constant, so measured differences are attributable to the enforcement layer.

Baselines. The primary comparator is B1 (FAPI 2.0-correct). B0 is reported only to contextualize how much of the benefit is already standard. All security claims are stated as P – B1.

Repetitions & statistics. Each experiment cell is repeated ≥ 20 –30 times with fixed seeds. Proportions (attack success, challenge rate) are reported with Wilson 95% intervals; latency with medians and p95/p99 and bootstrap CIs; P-vs-B1 differences with effect sizes (Cliff's delta for latency; risk difference / odds ratio for attack success), not p-values alone.

Environment. Single documented host; pinned image digests; warm-up excluded; load generator placement documented; hardware and versions reported for reproducibility.

Artifacts. Testbed, attack suite, load profiles, raw JSONL, and analysis notebooks released with a one-command bring-up (see Data Availability).

9. Discussion (*partial scaffold*)

9.1 What continuous enforcement adds over FAPI 2.0. [FILL to results] — frame around the measured A3/A4 delta and its cost. If, as hypothesized, B1 already neutralizes network/theft attacks and P's value concentrates on device-resident/ATO adversaries, say so plainly; that boundary characterization is the paper's point.

9.2 Cost model. [FILL] Discuss whether the overhead is dominated by policy/telemetry vs. crypto and what that implies for gateway deployment.

9.3 Usability trade-off. [FILL] Interpret the false-challenge rate; a defense that blocks A3/A4 but over-challenges legitimate users is not a net win.

9.4 Failure modes & misconfiguration. (*Keep from Vo, it is good.*) Improper DPoP clock-skew weakens replay protection or causes false rejections; stale device-key lifecycle management admits

replay; poorly calibrated thresholds either over-challenge or under-protect. These underscore that the benefit is contingent on correct configuration — and motivate the optional formal partial-deployment analysis (Appendix B / future work).

9.5 Threats to validity. Synthetic data and mock API limit external validity; the attacker set, though covering the discriminating cases, is not exhaustive; rule-based risk scoring is a deliberate design choice and an ML comparison is left to future work.

10. Limitations

The evaluation uses a synthetic, mock Open Banking environment rather than production infrastructure; results characterize authorization-semantic behavior and per-request cost, not bank-specific data effects. Device compromise at the OS/kernel level is out of scope. Risk scoring is rule-based; learned models may shift both the security/false-positive trade-off and the cost profile. Threshold calibration is illustrative; production tuning would require operational telemetry. These limitations bound the claims to the measured regime.

11. Ethics and Responsible Research

All experiments use synthetic data and a locally simulated ADR API; no real banking systems, production or staging endpoints, customer data, or credentials are involved. The attack implementations target only the authors' own local testbed and are provided to enable replication of the *defensive* evaluation, not as general-purpose offensive tooling. Because no external or third-party systems are touched, no vulnerability disclosure is applicable; had any real system been tested, coordinated disclosure would have been followed. Synthetic-data generation avoids any personal or financial information.

12. Conclusion (*partial scaffold*)

FAPI 2.0's mandatory sender-constraining already neutralizes the network- and theft-based token attacks that motivate much Open Banking security work, which reframes the question for Zero Trust from "does proof-of-possession help" to "what does continuous context-bound enforcement add beyond it, and at what cost." Using a reproducible, fully synthetic testbed and an identical attacker suite across a weak baseline, a FAPI 2.0-correct baseline, and a continuous-enforcement system, we [FILL: summarize the measured delta — for which adversaries P is necessary, its per-request cost, its false-challenge rate, and which component drives each]. [FILL: one-sentence practical takeaway for Open Banking deployers.] We release all artifacts to support replication and extension. Future work includes learned risk models, formal analysis of partial-deployment failure modes, and validation on production-grade workloads.

Data Availability

The testbed source code (mock ADR API, Keycloak configuration, Zero Trust controller, OPA policies), attack suite, load profiles, raw measurement records, and analysis notebooks are released at [FILL: repository URL] and archived at [FILL: Zenodo DOI]. All data are synthetic and generated by the released scripts. (*Replace Vo's "available upon reasonable request," which contradicts an open-testbed claim and is disfavored at the target venue.*)

Declaration of Generative AI Use

(Keep the Vo statement; it is appropriate. Ensure it remains accurate for the rewritten version.)

Appendix A — Belief-threshold model (demoted, optional)

If retained, present the belief-state formulation strictly as a *calibrated interpretation* of measured controller behavior: define `UpdateBelief` concretely, estimate its parameters from measured telemetry, and validate that the resulting thresholds predict the system's empirical `CHALLENGE/DENY` decisions. Position it explicitly as a quantal-response Stackelberg equilibrium over a belief-MDP and cite GAZETA [22] and the threshold-POMDP line [VERIFY: 2303.03349]. **Do not** claim a new equilibrium concept, and do not include un-instantiated "proof sketches." If it cannot be instantiated with measured parameters before submission, cut it — an un-grounded formalism weakens an otherwise empirical paper.

Appendix B — Optional formal partial-deployment analysis (future/secondary)

If pursued: model the composed checks (DPoP proof + controller verification + rebinding) in Tamarin/ProVerif under a Dolev-Yao attacker augmented with token theft, and show which partial deployments or misconfigurations (skew, missing resource-server check) reintroduce replay. A "misconfiguration reintroduces the attack" result complements the measurements and is independently publishable.

Change log vs. V0 (for your reference)

- **Reframed** from "novel architecture + new equilibrium" to "empirical measurement of P – B1." (Removes the two overclaimed novelty axes.)
- **Abstract** made honest and measurement-shaped; empirical claims now match the (forthcoming) evidence.
- **B1 (FAPI 2.0) baseline** introduced as the real comparator; B0 demoted to reference.
- **Device-resident + ATO adversaries moved in-scope** (they are the paper's reason to exist over FAPI 2.0).
- `cnf.jkt` **correction** throughout (was incorrectly `cnf.jwk`).
- **Game-theoretic section demoted** to an optional, must-be-instantiated appendix; "new equilibrium concept" claim removed; closest comparators (GAZETA, threshold-POMDP) now cited and differentiated.
- **Crypto background trimmed** to what the measurement needs.
- **Data Availability** changed from "upon request" to real artifact release.
- **Broken `Figure ??` references** and duplicated text to be fixed against the implemented system.